

README – Kit de Encuesta Pirámide del Dolor

Bienvenido/a a este pequeño artefacto diseñado para medir algo tan escurridizo como el dolor que infligimos (o no) a nuestros adversarios en el ciberespacio.

Este kit contiene:

1. Modelo de encuesta integral (01_encuesta_piramide_dolor.md)
2. Guía metodológica detallada (02_guia_metodologica.md)
3. Narrativa explicativa (03_narrativa_explicativa.md)
4. Mapeo de preguntas a normativa y marcos (04_mapeo_preguntas_normativa.md)
5. Plantilla de Excel para IGM y ROI (05_plantilla_excel_igm_roi.md)
6. Plantilla de reporte ejecutivo (PPT) (06_plantilla_reporte_ejecutivo_ppt.md)
7. Este README (07_README_kit_encuesta.md)

1. Propósito del kit

El objetivo es ofrecer un paquete coherente para:

- Evaluar la madurez de una organización en detección a lo largo de la Pirámide del Dolor.
- Traducir las respuestas de la encuesta en índices y métricas útiles.
- Comunicar los resultados de forma comprensible a la alta dirección.
- Conectar todo ello con obligaciones normativas y marcos de referencia habituales.

Si lo único que se consigue tras usar este kit es descubrir que se coleccionan más hashes de los que se entienden, ya habrá merecido la pena.

2. Cómo empezar (orden recomendado)

8. Leer la narrativa explicativa (03_narrativa_explicativa.md) para situar el enfoque.
9. Revisar la encuesta (01_encuesta_piramide_dolor.md) y adaptar mínimamente terminología si hace falta.
10. Consultar la guía metodológica (02_guia_metodologica.md) para decidir a quién y cómo se aplicará.
11. Aplicar la encuesta (en formato formulario o entrevista).
12. Codificar las respuestas en una hoja de cálculo según la plantilla de IGM y ROI.
13. Construir la presentación ejecutiva con ayuda de 06_plantilla_reporte_ejecutivo_ppt.md.

3. Personalización recomendada

- Sector: incorporar referencias sectoriales (p. ej., DORA, NIS sectoriales) en el mapeo normativo para salud, energía, finanzas, etc.
- Idioma: el kit está en español, pero se puede traducir manteniendo la lógica de las preguntas.
- Profundidad: puede simplificarse para organizaciones pequeñas (p. ej., omitiendo algunas preguntas avanzadas sobre ATT&CK).

La única recomendación firme es no eliminar por completo las preguntas que miran hacia la cúspide de la Pirámide (TTP, comportamiento). Son las que, a la larga, marcan la diferencia.

4. Versionado y mantenimiento

Se sugiere mantener un control de versiones del kit (por ejemplo, añadiendo un número de versión en este README):

- v1.0 – Versión inicial.
- v1.1 – Ajustes de ponderaciones y mapeos normativos.
- v2.x – Revisiones mayores (por cambios normativos significativos, nuevas prácticas de detección, etc.).

También es prudente revisar el contenido cada 2–3 años, especialmente ante cambios relevantes en:

- Marcos regulatorios (NIS2, ENS, etc.).
- Marcos técnicos (versiones de ATT&CK, nuevas taxonomías).
- Modelos de amenazas predominantes (por ejemplo, cambios en ransomware, OT, nube).

5. Buenas prácticas de uso

- Transparencia: explicar a las personas encuestadas para qué se utilizarán los resultados.
- Confidencialidad: tratar las respuestas con el mismo cuidado que se espera de cualquier dato sensible.
- Humildad: aceptar que la primera iteración será imperfecta; la mejora continua también aplica a las encuestas.
- Sentido del humor: un poco de ironía ayuda a hablar de temas serios sin caer en el dramatismo estéril.

6. Contacto y contribuciones

Si este kit se utiliza como base para trabajos colaborativos (por ejemplo, consorcios sectoriales, grupos de trabajo nacionales), es recomendable:

- Crear un repositorio (Git u otro) para gestionar cambios.
- Documentar las adaptaciones realizadas.
- Compartir lecciones aprendidas (sobre qué preguntas resultan más reveladoras, qué métricas son más útiles, etc.).

7. Descargo de responsabilidad

Este kit no sustituye:

- Una auditoría formal de cumplimiento.
- Una evaluación técnica exhaustiva de seguridad.
- El criterio profesional de quienes conocen en detalle la realidad de cada organización.

Lo que sí pretende es aportar una mirada particular: la de la Pirámide del Dolor como hilo conductor para ordenar el caos de indicadores, métricas y dashboards. Si después de usarlo alguien decide invertir un poco menos en perseguir IPs desechables y un poco más en entender y romper los hábitos del adversario, podremos considerarnos satisfechos.

Buen viaje por la Pirámide.